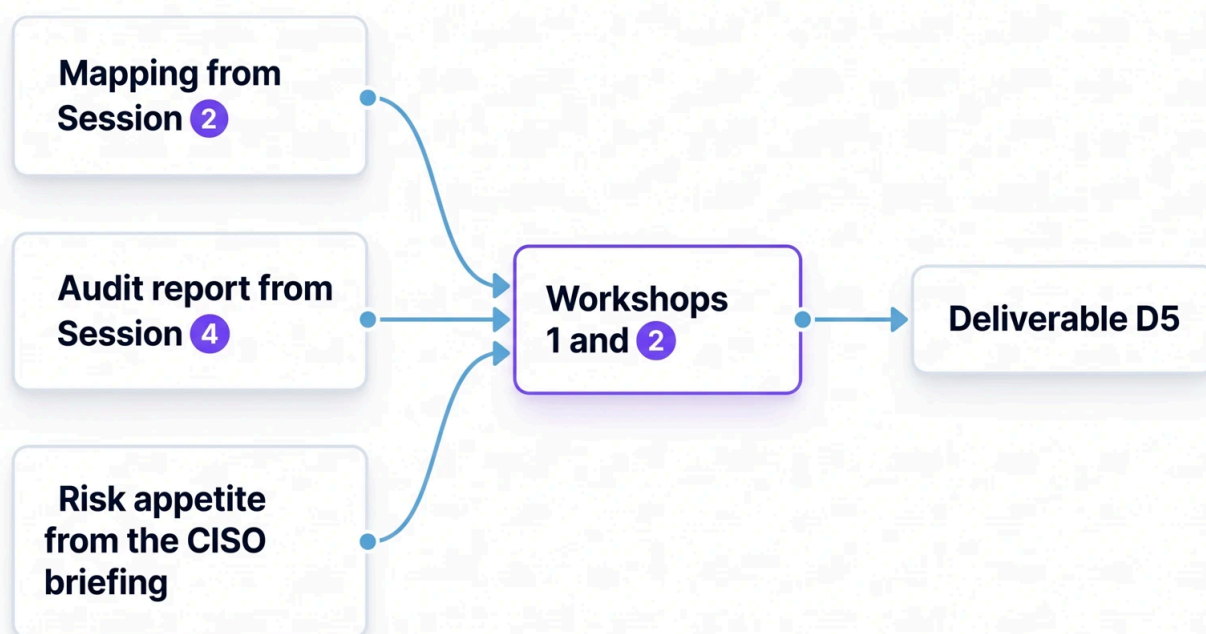


EBIOS RM Workshops 1 and 2: Baseline and risk origins

✓ The study opens: from the method to the work table



Session objectives

By the end of this tutorial:

- **Frame** an EBIOS Risk Manager (expression of needs and identification of security objectives, the ANSSI (the French national cybersecurity agency) method) study: objective, participants and roles, time frame, person responsible for accepting the residual risks
- **Reuse** the business assets and supporting assets from the mapping to delimit the study's business and technical scope

- **Formulate** feared events and estimate their severity from the DICT (availability, integrity, confidentiality, traceability, the French acronym kept by the module) security needs
- **Establish** the group's security baseline: applicable frameworks, state of application, justified deviations, decision on how to proceed
- **Build** and prioritize risk origin / target objective pairs, then cross-check them against the feared events

Prerequisites

- This morning's lecture: the vocabulary of risk and the mechanics of the five workshops.
- The mapping from session 2: business assets, supporting assets, DICT needs and the MERIDIAN group's Top 5 critical assets. Rule of the day: these objects are reused as they are, in the same terms; recreating them would be a methodological fault.
- The session 4 audit report and its deviations qualified by subsidiary: it becomes an input to Workshop 1.
- The risk appetite prepared at this morning's CISO briefing.

How the tutorial is set up

This tutorial runs the method's first two workshops on the MERIDIAN group, in the guide's order and with its deliverables. The four exercises follow the real steps of Workshop 1, framing, scope, feared events, baseline, then the whole of Workshop 2. Each exercise produces an element that will enter the end-of-day deliverable D5 as it is: nothing written here is disposable. The answer keys are gathered at the end of the lesson; the work is done without them, they are there to compare against, not to start from.

✓ Exercise 1: framing the study before analyzing anything at all

Workshop 1 begins with a step that beginners rush and that practitioners know to be decisive: the frame. A study without an explicit objective drifts; a study without named roles produces conclusions that no one owns.

The MERIDIAN group's Executive Management has approved the principle of a group-wide risk assessment, with a first cycle focused on the subsidiary under review, that is, the one whose pack the group holds, and on its main inter-subsidiary dependency from 56 of the subsidiary pack. For Santé as for Logistique, that dependency is the emergency replenishment flow between the two subsidiaries; for Éducation as for Territoires, it is the cluster's shared identity directory. The Group CISO facilitates the framing workshop.

To produce, in fifteen lines at most:

1. **Formulate** the study's objective in one sentence, choosing among the method's recognized purposes the one that matches Executive Management's request.
2. **Assemble** the participant table for Workshop 1: the four roles the guide expects, each embodied by an actor from the map of power of the subsidiary under review (§3 of the subsidiary pack) or of the holding company, with, for each, what they bring that the others do not.
3. **Designate** the person responsible for accepting the residual risks at the end of the study, in one sentence of justification grounded in the group's governance.
4. **Set** the time frame: the duration of the two cycles, with the reference that justifies this choice.

Method hint for point 2: ask who can say what matters to the business, who can say what the information system makes possible, who can say what security knows about the threat, and who can commit the group. Four questions, four chairs.

✓ Exercise 2: from the mapped estate to the feared events

The business and technical scope is not invented in session: it is taken over from the mapping. The material is what the group produced in session 2 for the subsidiary under review. Take three business assets from that mapping, then add as a fourth row the inter-subsidary dependency from §6 of the subsidiary pack. For each of the four rows, note the associated supporting assets and the dominant security need, on the model: business asset, supporting assets, dominant need.

This four-row table is the starting point, not the deliverable: the exercise consists in extending it toward what the group fears.

To produce:

1. **Formulate** six feared events, at least one per row of the table, inter-subsidary dependency included, each as a short phrase that names the business asset harmed and the security need affected. Walk through the four DICT needs so as not to produce six variations of the same event.
2. **Rate** the severity of each on the four-level scale seen in the lecture, from minor to critical, justifying each rating by the nature of the impacts: missions, regulation, people, image.
3. **Flag** the feared event for which specifying a duration changes the rating, and propose that specification.

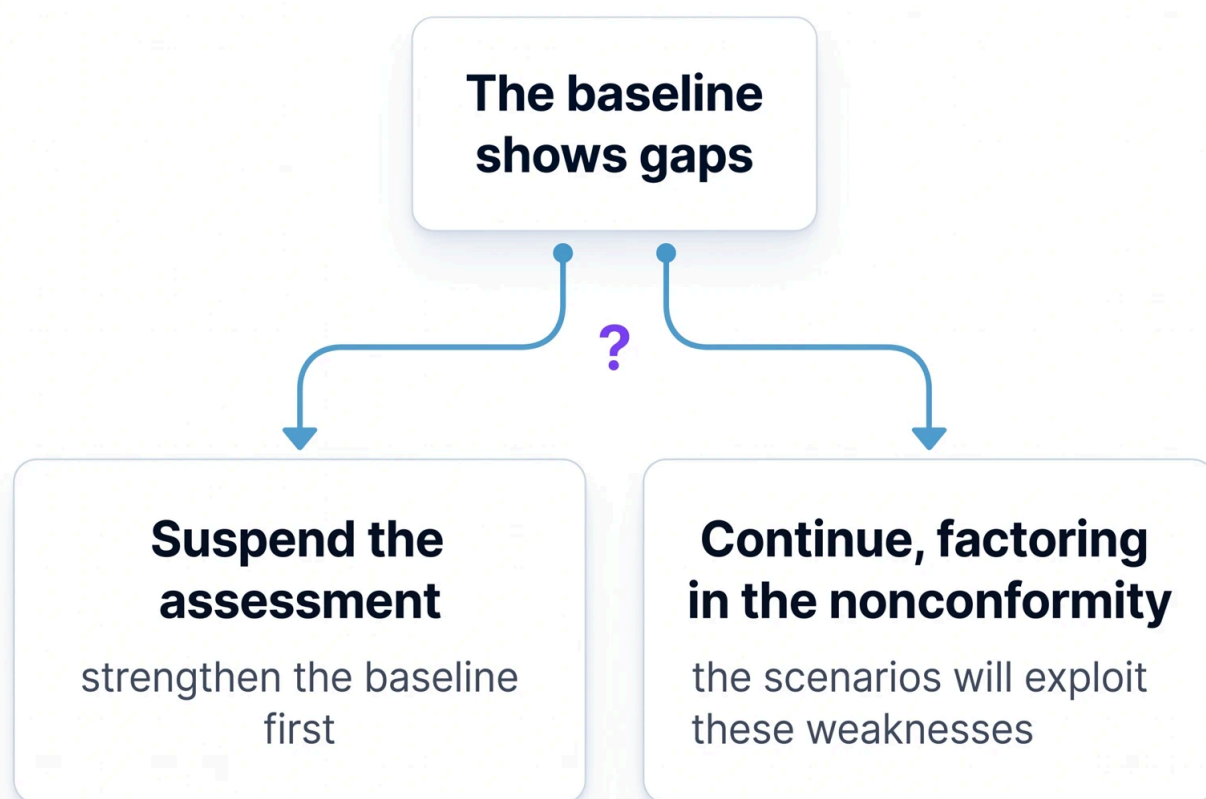
Hint for point 3: for harm to availability, the guide recommends specifying beyond what loss of service the severity level is reached. Each subsidiary pack carries at least one quantified duration case; one of the table's rows gains a lot from this.

Exercise 3: the security baseline, or the audit finding its place

Step D of Workshop 1 formalizes the security baseline. Almost everything already exists: the framework choice from session 3 and the audit report from session 4 are exactly the “state of application” the method asks for. The work is a rigorous assembly, not a new collection.

To produce: the security baseline table for the scope, on the guide's model, with four columns: type and name of the framework, state of application, deviations, justification of the deviations. It must cover the frameworks applicable to the subsidiary under review: the group's framework PSSI (the group's framework information security policy, French acronym) established in session 1, the ANSSI « guide d'hygiène informatique » (IT hygiene guide), ISO/IEC 27001:2022 chosen in session 3, and the subsidiary's own obligations as §2 of the subsidiary pack lists them (GDPR and health data hosting for Santé, the pharmaceutical customer's contractual requirements for Logistique, GDPR and minors' data for Éducation, the clauses of the delegation contracts and the twenty-four-hour notification deadline for Territoires). The deviations to carry over are the two findings of the reference pack's table for that subsidiary, as the session 4 audit report qualified them. The framework policy directives as codified in session 1 (ACC-01 to COR-01) are authoritative for this exercise, whatever wording the group adopted.

Then, in three sentences: the decision on how to proceed. The guide opens two paths when the baseline shows deviations, and only one is reasonable here. Which one, and why? And what consequence will this decision have on the following workshops?



Exercise 4: risk origins and target objectives

Switching sides. Workshop 2 answers the guide's question: who or what could harm the missions and business assets of Workshop 1, and to what ends? One piece of context to anchor the reflection in the real threat: ANSSI was made aware of 128 ransomware compromises in 2025. The healthcare sector remains a regular target of this type of attack, as shown in 2022 by the Centre Hospitalier Sud Francilien, victim of a ransomware attack claimed by the LockBit group.

To produce:

1. **Inventory** five candidate risk origin / target objective pairs for the scope of the subsidiary under review, drawing on the actors of §3 and §6 of its pack and varying the categories of origins: cybercriminals, competitors, activists, insiders. For each pair, one line: the origin, its target objective phrased as an end result, and the business asset it targets.

2. **Evaluate** the relevance of each pair against the guide's three criteria, motivation, resources, activity, on a three-position qualitative scale, justifying the activity column with an observable element.
3. **Select** the three pairs retained for the rest of the study, respecting the guide's selection rule: pairs that are sufficiently distinct and do not all impact the same business asset.
4. **Confront** the retained pairs with the feared events from exercise 2: build the correspondence table, and flag any serious feared event left without a plausible risk origin, or any retained pair without an associated feared event.

Trap to avoid, announced in the lecture and checked in the answer key: do not confuse the target objective with the motivation. "Getting rich" is not a target objective, it is what drives the origin; the target objective is phrased as a concrete result obtained at the group's expense.



Answer keys and assessment criteria — cliquer pour révéler